SECCIÓN 8.2

Comunicación clara de hallazgos técnicos

Temas de esta sección:

- Separar hechos de hipótesis y conclusiones
- Usar niveles de certeza adecuados
- Comunicar según el destinatario
- Evitar alarmismo y lenguaje vago

Un mensaje técnico efectivo separa claramente lo que se vio de lo que se interpreta:

HECHO

Lo que la evidencia muestra directamente. Reproducible y verificable.

Ejemplos:
- "WINWORD.EXE generó powershell.exe"
- "Conexión activa a 185.220.101.44:443"
- "Archivo svchost32.exe en C:\Users\Public\"

HIPÓTESIS

Interpretación razonada de los hechos. Puede ser incorrecta.

Ejemplos:
- "El comportamiento es compatible con ejecución de payload vía macro"
- "La conexión podría indicar actividad de C2"

CONCLUSIÓN

Determinación final, solo cuando la evidencia lo justifica.

Ejemplos:
- "Se confirma compromiso inicial vía phishing con macro maliciosa" (solo si hay suficiente evidencia)
- No: "el usuario fue hackeado" si no está confirmado

8.2 | Niveles de certeza: cómo comunicar lo que sabés

El nivel de certeza no es inseguridad — es precisión técnica. Usarlo mal genera alarma innecesaria o descarte incorrecto.

CONFIRMADO	La evidencia es directa, verificada y reproducible. → *"Se confirma ejecución de payload. Cadena: OUTLOOK → wscript → powershell. Archivo creado: svchost32.exe."*
PROBABLE	El comportamiento es consistente con una hipótesis pero no completamente verificado. → *"El comportamiento es compatible con initial access vía macro. Pendiente análisis del archivo y validación de alcance."*
POSIBLE	Hay indicios pero también otras explicaciones plausibles. → *"Se observa actividad compatible con reconocimiento interno. No descartado, pero puede ser tráfico legítimo de herramienta de inventario."*
PENDIENTE	No hay suficiente información todavía para determinar. → *"Alerta generada. Evidencia inicial revisada. Pendiente validación de contexto antes de determinar severidad."*

8.2 | Mensaje débil vs mensaje útil

La diferencia entre un mensaje débil y uno útil es concreta: uno genera acción, el otro genera preguntas.

```
Contexto: Se observa en endpoint FIN-LAP-022 la cadena de procesos WINWORD.EXE → powershell.exe con los flags: -nop -w hidden -enc [base64]
```

Mensaje débil

"Hay algo raro en una máquina de Finanzas. PowerShell ejecutó algo. Revisalo."

Problemas:

- No identifica el activo
- No indica el proceso ni los flags
- No da nivel de certeza
- No propone acción concreta
- No sirve para documentar ni escalar

Mensaje útil

"En FIN-LAP-022 (Finanzas) se observa WINWORD.EXE generando powershell.exe con flags -nop -w hidden -enc. El comportamiento es compatible con ejecución de payload vía macro. No se confirmó actividad posterior. Se recomienda verificar documento origen y evaluar aislamiento."

- Activo identificado
- Proceso y flags explícitos
- Nivel de certeza claro (compatible)
- Recomendación concreta

La estructura: activo → evidencia → nivel de certeza → impacto → recomendación.

8.2 | Comunicar según el destinatario

El mismo hallazgo requiere mensajes distintos según quién lo recibe y qué necesita hacer con él:

Líder de turno / L2	Resumen rápido, evidencia clave, certeza, acción sugerida	*"FIN-LAP-022: WINWORD→PS -enc activo. Compatible con macro payload. Recomiendo validar aislamiento."*
Equipo de IR	Evidencia técnica completa, IOCs, timeline, cadena de procesos	*"Cadena: WINWORD.EXE → powershell.exe -nop -w hidden -enc [base64]. Archivo: update.exe en C:\Users\Public\. Conexión: billing-check-update.net:443 (activa)."*
Legal / Compliance	Hechos sin jerga, impacto en datos, acciones tomadas	*"Se detectó actividad sospechosa en equipo del área de Finanzas que podría comprometer archivos de la organización. Se procedió a aislar preventivamente."*
Usuario afectado	Mínimo necesario, sin datos de la investigación, sin alarmar	*"Tu equipo fue aislado por precaución. Nos comunicamos pronto para coordinar la restitución."*

8.2 | Ejercicio: reescribir el hallazgo

Reescribí estas conclusiones usando hechos, hipótesis y nivel de certeza adecuado:

1	*Original: "El usuario fue hackeado y robó datos."* Pista: Separar actividad observada de conclusión. ¿Qué se vio exactamente?
2	*Original: "Hay un virus en la red, hay que apagarlo todo."* Pista: ¿Qué evidencia hay? ¿Cuál es el alcance real? ¿Qué acción específica se recomienda?
3	*Original: "Esto parece phishing, no sé si importa."* Pista: Definir certeza. ¿Hay IOCs? ¿Impactó a usuarios? ¿Requiere acción?